

REPORT DI INCIDENT RESPONSE: COMPROMISSIONE SISTEMA B

ID Incidente: INC-20260507-01

Data: 07 Maggio 2026

Redatto da: Team CSIRT (Cyber Security Incident Response Team)

Oggetto: Analisi, Isolamento e Bonifica del Server Database (Sistema B)

Stato: In Corso (Fase di Contenimento ed Eradicazione)

Severità: Critica

1. SINTESI DELL'EVENTO

Il Sistema B, identificato come server database con storage multi-disco all'interno della rete interna, è stato oggetto di una compromissione totale da parte di un attaccante esterno. L'accesso è avvenuto tramite Internet superando le difese perimetrali. L'attacco è attualmente attivo.

2. TECNICHE DI ISOLAMENTO

L'obiettivo immediato è impedire il movimento laterale dell'attaccante verso gli host A, C e D e bloccare l'esfiltrazione di dati verso l'esterno.

I. Isolamento di Rete (Network Isolation)

- Segmentazione Logica:** Configurazione immediata sul firewall perimetrale di una regola "Deny All" (Inbound/Outbound) specifica per l'indirizzo IP del Sistema B.
- VLAN di Quarantena:** Spostamento del sistema in una VLAN isolata (Sandbox) priva di connettività verso il resto della rete aziendale, per permettere il monitoraggio del traffico malevolo a scopi di analisi.
- Sconnessione Fisica:** Se l'attacco non può essere contenuto logicamente, si procede alla rimozione del cavo di rete dallo switch di competenza.

II. Isolamento Host-Based

- Revoca Credenziali:** Disabilitazione immediata di tutti gli account utente e delle chiavi SSH depositate sul sistema.
- Interruzione Processi:** Laddove possibile senza compromettere l'analisi forense, terminazione dei processi sospetti identificati.

3. RIMOZIONE DEL SISTEMA INFRETTTO

Una volta garantito l'isolamento, il sistema deve essere rimosso dalla produzione seguendo questi step:

1. **Acquisizione Volatile (Memory Dump):** Prima dello spegnimento, viene effettuata una copia della RAM per analizzare malware residenti in memoria e chiavi di cifratura attive.
2. **Spegnimento Controllato:** Arresto del sistema per prevenire ulteriori alterazioni dei dati.
3. **Imaging Forense:** Estrazione fisica dei dischi e creazione di una copia bit-a-bit (immagine forense) su un supporto esterno protetto da scrittura, per analisi post-mortem in ambiente sicuro (Air-gapped).

4. SANITIZZAZIONE E SMALTIMENTO DISCHI

Prima di procedere allo smaltimento dei dischi compromessi o al loro eventuale riutilizzo, è necessario applicare protocolli di Data Sanitization (Standard NIST SP 800-88).

Tecnica	Descrizione	Livello di Protezione
CLEAR	Sovrascrittura dei dati sensibili utilizzando comandi software standard (es. riempimento con zeri o pattern casuali).	Base: Protegge dal recupero dati effettuato con software comuni. Il supporto è riutilizzabile.
PURGE	Utilizzo di metodi fisici (Degaussing) o logici avanzati (Crypto Erase) per rimuovere i dati anche dalle aree nascoste del disco.	Avanzato: Rende i dati irrecuperabili anche con tecniche di laboratorio forense.
DESTROY	Distruzione fisica del supporto tramite triturazione (shredding), incenerimento o polverizzazione.	Massimo: Garantisce l'impossibilità fisica di ricostruire i dati. Obbligatorio per dati altamente critici.

Differenza tra Purge e Destroy

- Il **Purge** mira a rendere i dati irrecuperabili agendo sulla struttura magnetica o logica del disco, permettendo in alcuni casi il riutilizzo dell'hardware (tranne nel caso del degaussing su dischi magnetici che li rende inutilizzabili).
 - Il **Destroy** è l'opzione finale che trasforma l'hardware in rifiuto fisico; è l'unico metodo che dà la certezza matematica dell'impossibilità di recupero anche di frammenti di dati, poiché il supporto fisico cessa di esistere nella sua forma originale.
-

Note Finali: Si raccomanda, al termine dell'operazione, il reset di tutte le password amministrative della rete interna e il patching delle vulnerabilità che hanno permesso l'accesso iniziale al firewall.

RELAZIONE TECNICA SOC/CSIRT: ANALISI ATTACCO ENDPOINT

Data: 07 Maggio 2026

Destinatari: Responsabile IT / Team di Sicurezza

Oggetto: Analisi delle attività sospette segnalate su due workstation aziendali

1. SINTESI DELL'INCIDENTE

A seguito della segnalazione di anomalie da parte di due utenti, il team SOC ha analizzato le evidenze raccolte. L'attacco segue una catena di infezione strutturata che mira al controllo persistente del traffico di rete e del sistema operativo attraverso tecniche di "Living off the Land" (uso di strumenti legittimi per scopi malevoli).

2. ANALISI TECNICA DELLE EVIDENZE

Fase I: Manipolazione del Traffico (Analisi Link 1)

L'evidenza mostra la creazione e l'apertura tramite PowerShell del file **DNS_Changer.ps1**.

- **Azione:** Lo script tenta una *Privilege Escalation* per ottenere diritti di Amministratore e modificare i server DNS dell'interfaccia Wi-Fi.
- **Obiettivo (DNS Hijacking):** Reindirizzare il traffico web degli utenti verso server controllati dall'attaccante. Questo permette di intercettare credenziali attraverso pagine di phishing perfettamente clonate, anche se l'utente digita URL corretti.

Fase II: Monitoraggio e Persistenza (Analisi Link 2)

Dopo l'infezione iniziale, l'attaccante ha scaricato la suite **Microsoft Sysinternals** per operare in modo indisturbato.

- **Monitoraggio con Process Explorer:** Nello screenshot si osserva l'analisi dei processi attivi. L'evidenziazione in rosso di processi di sistema (SearchProtocolHost.exe) indica tentativi di iniezione di codice o sospensione di servizi che potrebbero ostacolare l'attacco (come antivirus o EDR).
 - **Configurazione Persistenza con Autoruns:** L'attaccante sta mappando le chiavi di registro di Windows per inserire lo script malevolo tra i programmi ad avvio automatico. L'obiettivo è garantire che l'attacco rimanga attivo anche dopo un riavvio del computer.
-

3. VALUTAZIONE DEL RISCHIO

L'attacco è classificato come **ALTO**. Non si tratta di un evento isolato, ma di un tentativo di stabilire una testa di ponte nella rete aziendale per:

1. Rubare identità digitali (tramite DNS manipolati).
2. Effettuare movimenti laterali verso server critici (come il già compromesso **Sistema B**).
3. Mantenere una persistenza silente difficile da rilevare senza strumenti di analisi avanzata.

4. PIANO DI INTERVENTO E RACCOMANDAZIONI

Azioni Immediate (Incident Response)

- **Isolamento Host:** Distacco immediato dei due computer dalla rete per bloccare comunicazioni verso i server C2 (Command & Control) dell'attaccante.
- **Ripristino Configurazioni:** Reset forzato dei server DNS ai valori aziendali standard e rimozione delle chiavi di avvio sospette identificate con Autoruns.
- **Bonifica Account:** Reset obbligatorio delle password di dominio per gli utenti coinvolti, con revoca di tutti i token di accesso attivi.

Misure di Prevenzione (Post-Mortem)

- **PowerShell Execution Policy:** Configurare una GPO per impedire l'esecuzione di script PowerShell non firmati digitalmente dall'azienda.
- **Restrizione Strumenti:** Bloccare l'esecuzione di utility amministrative (come la suite Sysinternals) agli utenti non appartenenti al reparto IT.
- **Hardening DNS:** Implementare filtri DNS a livello di rete (DNSSEC/Umbrella) per impedire modifiche locali non autorizzate.

Firma: *Analista SOC - Team CSIRT*

Report di Installazione e Monitoraggio: Wazuh SIEM

1. Obiettivo dell'Attività

L'obiettivo del laboratorio è l'implementazione di una soluzione **SIEM (Security Information and Event Management)** per il monitoraggio in tempo reale di un endpoint (Kali Linux) tramite la piattaforma **Wazuh**. L'attività ha compreso l'installazione dell'agent, l'enrollment sicuro e l'analisi iniziale delle vulnerabilità.

2. Architettura del Laboratorio

- **Wazuh Manager:** Distribuito tramite immagine OVA (Indirizzo IP: 192.168.1.27).
 - **Wazuh Agent:** Installato su sistema operativo Kali Linux.
 - **Connettività:** Le macchine sono state configurate in una rete locale virtuale per permettere la comunicazione sulle porte TCP 1514 (invio log) e 1515 (registrazione).
-

3. Fasi Operative

A. Configurazione del Repository e Installazione

È stata configurata la sorgente pacchetti ufficiale di Wazuh su Kali Linux. A causa di limitazioni iniziali sui permessi di scrittura nei file di sistema, è stato utilizzato il comando: `sudo sh -c 'echo "deb [...]" > /etc/apt/sources.list.d/wazuh.list'` per garantire la corretta creazione del repository, seguito da un aggiornamento degli indici tramite `apt-get update`.

B. Enrollment dell'Agent

L'enrollment è stato eseguito tramite il metodo della configurazione manuale. Il file `/var/ossec/etc/ossec.conf` è stato modificato inserendo l'indirizzo IP del Manager e definendo un nome identificativo personalizzato per l'endpoint:

- **Manager IP:** 192.168.1.27
- **Agent Name:** Kali-Lab.

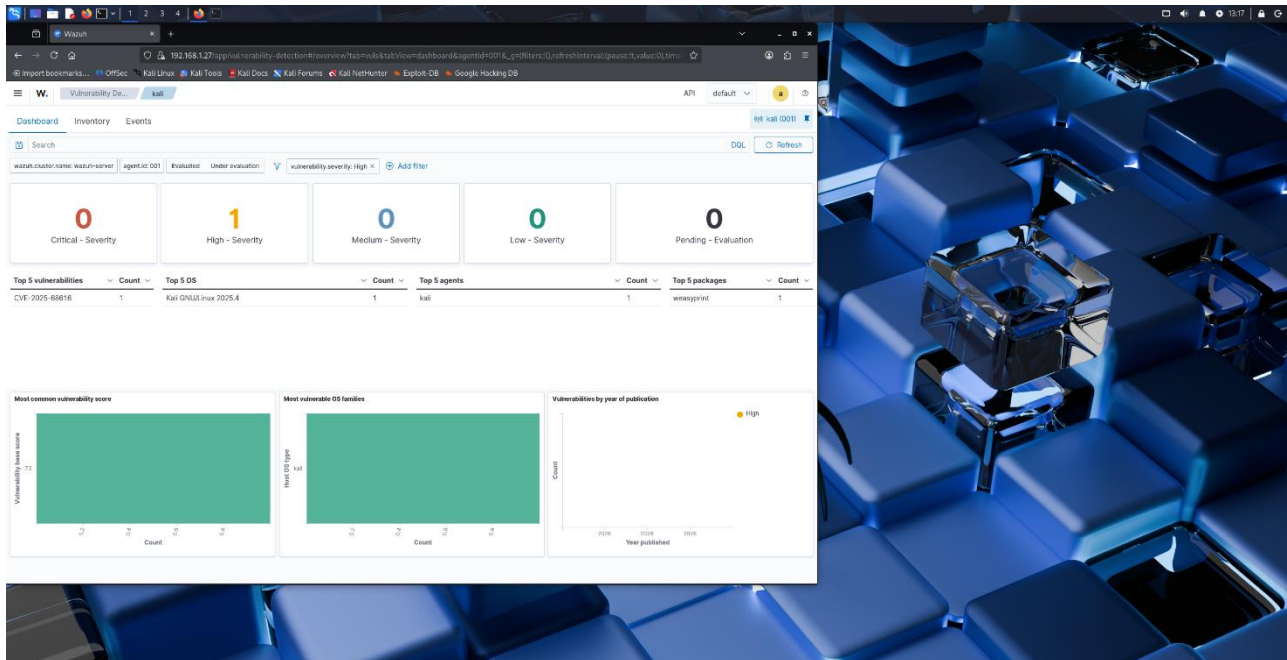
Il servizio è stato attivato correttamente tramite `systemctl restart wazuh-agent`.

4. Analisi dei Risultati (Security Findings)

I. Vulnerability Detection

Il modulo di scansione delle vulnerabilità ha rilevato diverse falle di sicurezza sul sistema Kali.

- **Caso Rilevante:** È stata identificata una vulnerabilità di livello **HIGH** nel pacchetto **WeasyPrint**.



- **Rischio:** Tali vulnerabilità potrebbero permettere a un attaccante di eseguire codice remoto o accedere a file riservati tramite la manipolazione di processi di conversione PDF.

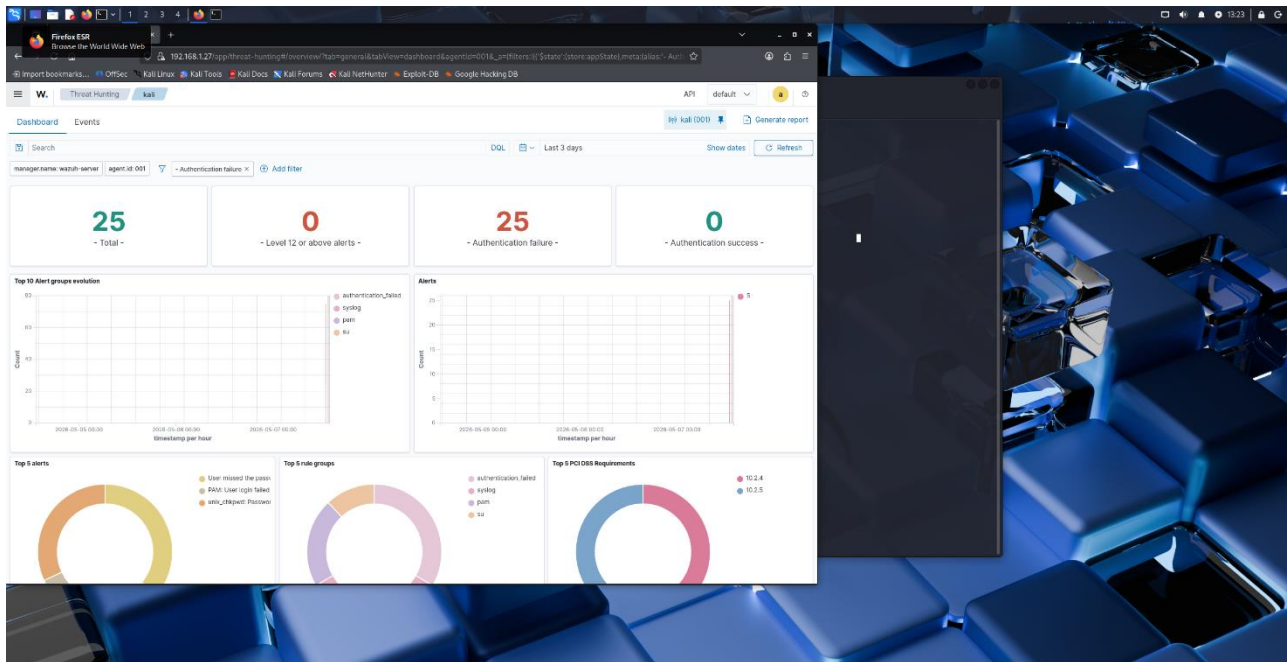
II. Security Configuration Assessment (SCA)

Il sistema ha eseguito un check delle configurazioni di sicurezza (Hardening).

- **Esito:** Sono stati rilevati diversi "Fail" riguardanti la configurazione dei servizi di sistema, indicando la necessità di ottimizzare le policy di accesso e i permessi dei file sensibili.

III. Monitoraggio degli Eventi

La dashboard ha confermato la ricezione dei log in tempo reale. Sono stati registrati eventi relativi all'integrità dei file e ai tentativi di accesso al sistema.



5. Conclusioni e Raccomandazioni

L'installazione ha avuto successo e l'agent risulta **Active**. Sulla base di quanto rilevato, si raccomanda di:

1. **Patch Management:** Aggiornare immediatamente il pacchetto weasyprint e gli altri pacchetti vulnerabili segnalati.
2. **Hardening:** Seguire le linee guida fornite dal modulo SCA di Wazuh per correggere le configurazioni deboli del sistema operativo.
3. **Monitoraggio Continuo:** Verificare periodicamente il modulo *Threat Hunting* per identificare pattern di attacco anomali.

Analista: Antonio Oricchio **Data:** 07/05/2026 **Stato Endpoint:** Connesso (Active)